

Relatório Técnico de Governança de TI - Ride Buddy

Informações Institucionais

Instituição: Instituto Federal de São Paulo - Campus Bragança Paulista

Curso: Tecnologia em Análise e Desenvolvimento de Sistemas (ADS)

Módulo: 6º Módulo

Disciplina: Governança de Tecnologia da Informação

Docente: Profa. Letícia Souza Netto Brandi

Data de Emissão: 21 de Maio de 2026

Participantes:

Márcio Brener de Moraes — Prontuário: BP304470X

Marco Aurélio Nichi Rodermei — Prontuário: BP3044149

Tiago Silva Fernandes — Prontuário: BP3044254

Willian Rodrigues Spada — Prontuário: BP3044106

1. Resumo do Projeto (BRAGOTI)

O projeto **Ride Buddy** consiste em uma aplicação mobile desenvolvida utilizando o framework Flutter (linguagem Dart), cujo principal objetivo é atuar como uma plataforma de controle financeiro e de despesas operacionais voltada especificamente para motoristas de aplicativos de transporte autônomos (tais como Uber, 99, InDrive, entre outros). A relevância social e econômica do projeto reside na mitigação de uma assimetria de informação crônica na categoria: a dificuldade em consolidar o faturamento bruto deduzido dos custos operacionais reais (combustível, manutenção, seguro e taxas de intermediação).

A arquitetura técnica do ecossistema mobile adota o paradigma *online-first*, garantindo que o motorista de aplicativo consiga registrar os dados de suas corridas de forma imediata e resiliente. A persistência local de dados é estruturada para suportar a integridade transacional de registros como: plataforma de origem, distância percorrida em quilômetros, coordenadas de origem e destino, valor bruto recebido e data/horário da operação.

2. Alinhamento Estratégico: Objetivos de Negócio e TI

Para estabelecer um modelo de governança corporativa sólido, o Ride Buddy passa pelo alinhamento estratégico entre os objetivos da atividade de extensão (o negócio do motorista parceiro) e a entrega de valor da tecnologia (a solução em Flutter), utilizando a Cascata de Objetivos do COBIT 2019:

Objetivos de Negócio (EG01 - Portfólio de Produtos e Serviços Competitivos)

Prover ao motorista uma ferramenta autônoma que transforme dados brutos de viagens em uma visão analítica real de sua margem de lucro, permitindo que ele escolha estrategicamente as melhores plataformas de atuação e maximize sua rentabilidade por hora trabalhada.

Objetivos de Alinhamento de TI (AG07 - Segurança da Informação, Infraestrutura de Processamento e Aplicações)

Garantir que os dados financeiros e geográficos do usuário estejam protegidos localmente e que as fórmulas matemáticas aplicadas pelo framework Flutter sejam imutáveis e livres de falhas de processamento, assegurando alta resiliência e confidencialidade.

3. Seleção e Justificativa de Processos COBIT 2019

Com base nos guias de referência do framework COBIT 2019, foram selecionados seis processos críticos para estruturar a governança e a gestão do ciclo de vida de desenvolvimento e operação do ecossistema Ride Buddy.

3.1. Camada de Governança (Avaliar, Direcionar e Monitorar)

- **EDM02 (Assegurar a Entrega de Benefícios):** Este processo garante que o esforço de codificação do grupo gere valor real para o motorista. No Ride Buddy, isso se traduz em auditar se as métricas finais apresentadas na interface (R\$/km rodado e lucro líquido por hora) são matematicamente exatas e fáceis de interpretar, impedindo que o motorista tome decisões erradas baseadas em relatórios imprecisos.
- **EDM03 (Assegurar a Otimização de Riscos):** Determina as diretrizes sobre o que o projeto aceita ou não como risco. Ele direciona a equipe a decidir a arquitetura de dados; por exemplo, a decisão de adotar uma arquitetura paradigma online-first (armazenamento estrito no aparelho) é uma diretriz deste processo para evitar a perda de dados caso o aparelho seja extraviado.

3.2. Camada de Gestão

- **APO12 (Gerenciar Riscos):** Atua no nível do ecossistema integrado da aplicação (Flutter + Firebase Cloud). Mapeia e trata os riscos operacionais e de integridade vivenciados pelo motorista autônomo no cotidiano das ruas, tais como: a perda de registros financeiros salvos provisoriamente no cache local e ainda não sincronizados com a nuvem (caso o smartphone sofra um desligamento abrupto por falta de bateria ou avaria física nas vias urbanas); conflitos de concorrência e divergência de dados quando o dispositivo retoma a conectividade celular; a inserção acidental de dados inconsistentes de viagens pelo usuário nos formulários (ex: valor de corrida negativo ou quilometragem zerada), que corromperiam as métricas analíticas de lucro líquido; e o monitoramento contra o esgotamento de cotas de leitura/escrita do plano do Firebase, que poderia indisponibilizar a solução para a categoria.
- **APO13 (Gerenciar a Segurança):** Responsável por estabelecer e implementar os controles lógicos tanto na aplicação cliente (Flutter) quanto no ambiente de nuvem, visando blindar a privacidade financeira e a rotina do trabalhador. Ele dita a necessidade imperativa de configurar e auditar as Regras de Segurança do Firestore (*Firestore Security Rules*), garantindo o isolamento absoluto de dados na nuvem para que um motorista jamais consiga acessar ou modificar os dados financeiros e geográficos de outro. Além disso, rege o controle seguro do ciclo de vida dos tokens de acesso via *Firebase Authentication* e a aplicação de técnicas de ofuscação de código no Dart, mitigando riscos de engenharia reversa e adulterações no arquivo .apk distribuído.
- **BAI03 (Gerenciar a Identificação e Construção de Soluções):** Rege a engenharia, design e o desenvolvimento do ecossistema tecnológico. Este processo justifica a viabilidade técnica de construir o aplicativo combinando o framework Flutter (para renderização de uma interface híbrida multiplataforma performática a partir de uma única base de código Dart) e a plataforma Firebase (como infraestrutura NoSQL elástica). Ele controla a homologação e inserção de pacotes oficiais do ecossistema Dart (ex: `cloud_firestore` e `firebase_auth`), assegurando que a solução física construída espelhe exatamente os requisitos funcionais e as necessidades de análise de margem de lucro levantadas com a categoria de motoristas.
- **MEA03 (Gerenciar a Conformidade com Requisitos Externos):** Garante que o aplicativo não viole leis vigentes. No contexto do Ride Buddy, este processo faz a verificação contínua das telas e fluxos de dados para assegurar conformidade total com a LGPD, mapeando se o usuário deu consentimento claro e possui direitos sobre suas informações.

4. Avaliação do Nível de Capacidade dos Processos

A avaliação de capacidade adota a escala conceitual baseada na ISO/IEC 15504 preconizada pelo COBIT 2019 (Níveis de 0 a 5):

Processo COBIT	Nível Atual	Estado Atual e Evidências Técnicas	Lacunas (Gaps) Detectadas
EDM02	Nível 2 (Gerenciado)	Telas de relatórios construídas no Flutter que calculam automaticamente indicadores financeiros a partir dos inputs.	Falta de testes de usabilidade homologados diretamente por motoristas reais.
EDM03	Nível 1 (Executado)	Opção arquitetural de manter os dados em nuvem (Firebase Cloud), permitindo a consolidação e sincronização instantânea do faturamento dos motoristas.	Ausência de uma matriz formal de apetite a riscos aprovada pela gestão que contemple o gerenciamento de vulnerabilidades em ambientes de nuvem pública e o impacto de falhas na comunicação cliente-servidor.
APO12	Nível 1 (Executado)	Uso de blocos try/catch no Dart para interceptar falhas de input e masks de validação nos formulários.	Falta de uma rotina automática de backup local criptografado em arquivo externo (ex: exportar para .csv seguro).
APO13	Nível 1 (Executado)	Isolamento nativo de dados em nível de sistema operacional através da estrutura	Falta de testes unitários e integrados.

Processo COBIT	Nível Atual	Estado Atual e Evidências Técnicas	Lacunas (Gaps) Detectadas
		de Sandbox do Android/iOS.	
BAI03	Nível 2 (Gerenciado)	Código-fonte modularizado em Dart (GitHub), utilizando o arquivo <code>pubspec.yaml</code> para mapear e documentar os SDKs oficiais e homologados do Firebase.	Ausência de documentação técnica arquitetural formalizada (ex: modelagem de coleções NoSQL do Firestore ou diagramas de componentes lógicos).
MEA03	Nível 1 (Executado)	Mapeamento conceitual da LGPD realizado pelo grupo durante as etapas de modelagem do escopo do aplicativo.	Ausência de uma tela visível de Política de Privacidade e Termos de Uso dentro do fluxo de navegação do app.

5. Matriz RACI de Responsabilidades

Abaixo está descrita a distribuição de responsabilidades para os seis processos estudados, mapeando os papéis reais dos integrantes baseados no ciclo de vida de desenvolvimento:

- **PO / Analista de Requisitos:** Tiago Silva Fernandes
- **Dev Lead (Flutter):** Márcio Brener de Moraes
- **Analista de QA / Segurança:** Marco Aurélio Nichi Rodermele
- **Analista de Governança / Compliance:** Willian Rodrigues Spada

Processo COBIT	Tiago (PO)	Márcio (Dev)	Marco (QA)	Willian (Gov)
EDM02	A	R	C	C

Processo COBIT	Tiago (PO)	Márcio (Dev)	Marco (QA)	Willian (Gov)
(Benefícios)				
EDM03 (Riscos Gov)	C	I	R	A
APO12 (Gerenciar Riscos)	I	R	A	R
APO13 (Segurança)	I	R	A	C
BAI03 (Construção)	C	A	R	I
MEA03 (Conformidade)	R	I	C	A

Legenda: R = Responsible (Executor) | A = Accountable (Aprovador/Responsável Final) | C = Consulted (Consultado) | I = Informed (Informado).

6. Engenharia de Privacidade e Conformidade LGPD (Lei 13.709/18)

O Ride Buddy trata dados que expõem intimidades financeiras e rotinas diárias precisas dos usuários (alta criticidade contextual). Para mitigar riscos e assegurar a legalidade, estruturou-se a matriz de tratamento de dados abaixo:

Dado Tratado	Classificação	Base Legal (Art. 7º)	Risco Identificado	Controle de TI Proposto	COBIT
Locais de Saída e Chegada (Endereços e Geoinformação)	Dado Pessoal Comum de Alta Criticidade Contextual	Execução de Contrato (Inciso V)	Acesso não autorizado ao histórico de rotinas e endereços frequentados pelo motorista e passageiros por engenharia reversa no banco local.	Uso da biblioteca <i>flutter_secure_storage</i> para criptografia AES em nível de chave das strings geográficas salvas.	APO13
Valores Financeiros das Corridas e Custos operacionais	Dado Pessoal Comum (Financeiro / Proteção à Intimidade)	Legítimo Interesse do Controlador (Inciso IX)	Furto ou perda física do smartphone com o aplicativo aberto, expondo toda a receita e faturamento privado do trabalhador.	Implementação do pacote <i>local_auth</i> em Flutter, exigindo biometria (Fingerprint/FaceID) na inicialização do app.	APO12
Data, Horário e Plataforma de Origem (Uber, 99, InDrive)	Dado Pessoal Comum (Dados de Registro Operacional)	Legítimo Interesse do Controlador (Inciso IX)	Cruzamento de metadados temporais criando um perfil comportamental comercializável (*profiling*) sem autorização.	Garantia arquitetural de isolamento absoluto: o app não possui rotinas de telemetria externa, mantendo os dados salvos apenas no	APO13

Dado Tratado	Classificação	Base Legal (Art. 7º)	Risco Identificado	Controle de TI Proposto	COBIT
				dispositivo.	

7. Plano de Melhorias (Roadmap de Governança de TI)

Com o intuito de mitigar as lacunas e elevar o nível de capacidade geral dos processos corporativos para o Nível 3 (Definido), a equipe estabeleceu o seguinte plano estratégico:

1. **Curto Prazo (Prazo: 2 semanas):** Adicionar uma tela de Onboarding em Flutter que exiba os Termos de Uso e a Política de Privacidade antes do primeiro acesso do motorista, exigindo o aceite formal. O texto deixa claro que os dados não saem do dispositivo (MEA03).
2. **Médio Prazo (Garantia de Integridade):** Implementação de uma suíte de testes unitários automatizados diretamente na camada lógica do aplicativo (camada de controle/regras de negócio). O foco será blindar matematicamente as funções que calculam o lucro líquido e o custo por quilômetro rodado (R\$/km). Esta melhoria garante que qualquer evolução futura no código do aplicativo não quebre os cálculos centrais entregues ao usuário, mitigando riscos de relatórios financeiros corrompidos (APO12) e elevando a maturidade da engenharia do software (BAI03).
3. **Longo Prazo (Fase de Manutenção e Expansão):** Criação de um botão nativo nas configurações chamado "Excluir Minha Conta e Dados", executando um comando de purga total no banco de dados local, cumprindo o direito fundamental do titular à eliminação de dados garantido pela LGPD.

8. Referências

- ISACA. **COBIT 2019 Framework: Governance and Management Objectives**. Schaumburg, IL: ISACA, 2018.
- BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF, 2018.
- FLUTTER. **Security practices for Flutter mobile applications**. Disponível em: <<https://docs.flutter.dev>>. Acesso em: 21 de maio de 2026.